

Ex4-1

才子桓 2212700 密码科学与技术

实验要求

调研一种现实中存在的协议，找出其中实现“挑战-响应”身份认证机制的部分要求：

1. 简述这个协议的功能，以及在哪里使用了身份认证
2. 抽象描述其中的身份认证机制（用课本上描述协议的方法）
3. 给出这个协议确实使用了这种身份认证的证据（协议的文档/说明/标准/论文/抓个包指出用于身份认证的字段等等，都可以）

实验过程

这里我选择的常见的使用“挑战-响应”机制进行身份认证的协议是 Kerberos 协议。

问题1

简述这个协议的功能，以及在哪里使用了身份认证？

Kerberos 协议主要用于分布式计算环境中的身份认证，确保用户和服务端的身份可信，防止凭证被冒用或篡改。它主要应用于网络服务的身份验证和授权，例如企业内部网络的用户身份验证和系统资源的访问控制。

在 Kerberos 协议中，身份认证是在用户登录和请求访问受保护资源时进行的，确保用户和资源的身分可靠且不可伪造。

问题2

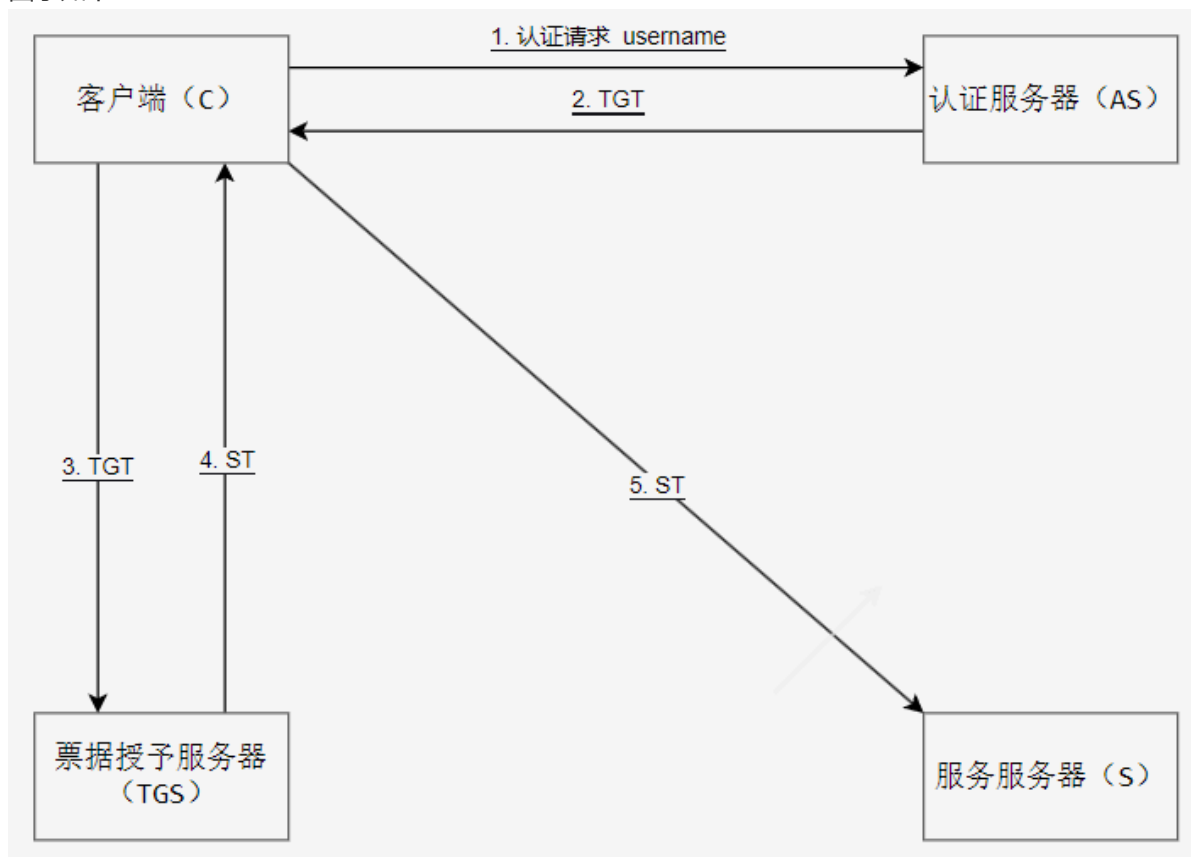
抽象描述其中的身份认证机制（用课本上描述协议的方法）。

协议 4.1.1 Kerberos 协议

Kerberos 协议中通常需要四方完成，客户端（C）、认证服务器（AS）、票据授予服务器（TGS）和服务服务器（S）。

1. C 向 AS 发起一个认证请求，该请求包含客户端的标识信息，通常是 username。
2. AS 查询自己的数据库验证请求者的身份，若身份验证成功，会生成一个“票证授予票据”（TGT）。
3. C 收到 TGT 后，会向 TGS 请求服务票据。
4. TGS 收到请求后，验证 TGT 的有效性，并发放一个服务票据（ST）给C。
5. C 携带 ST 向 S 请求服务。
6. S 验证 ST 的有效性，验证通过则允许客户端访问服务。

图示如下：



问题三

给出这个协议确实使用了这种身份认证的证据（协议的文档/说明/标准/论文/抓个包指出用于身份认证的字段等等，都可以）。

Kerberos 协议的标准文档：[Kerberos 协议的标准文档 RFC 4120](https://www.rfc-editor.org/rfc/rfc4120)

Microsoft Ignite 中关于 Kerberos 协议的部分：<https://learn.microsoft.com/zh-cn/windows/win32/secauthn/microsoft-kerberos>

1. 客户端在 KRB_AS_REQ 消息中包含一个随机生成的 nonce，用于检测重放攻击。服务器在回复 KRB_AS_REP 消息时也包含相同的 nonce，用于验证回复与请求匹配。这种机制类似于挑战-响应中的“挑战”，客户端和服务端都使用相同的密钥生成响应，从而证明它们知道这个密钥。

相关内容如下：

Section 3.1.1

The client may specify a number of options in the initial request. Among these options are whether pre-authentication is to be performed; whether the requested ticket is to be renewable, proxiable, or forwardable; whether it should be postdated or allow postdating of derivative tickets; and whether a renewable ticket will be accepted in lieu of a non-renewable ticket if the requested ticket expiration date cannot be satisfied by a non-renewable ticket (due to configuration constraints).

The client prepares the KRB_AS_REQ message and sends it to the KDC.

Section 3.1.2

Because Kerberos can run over unreliable transports such as UDP, the KDC MUST be prepared to retransmit responses in case they are lost. If a KDC receives a request identical to one it has recently processed successfully, the KDC MUST respond with a KRB_AS_REP message rather than a replay error. In order to reduce ciphertext given to a potential attacker, KDCs MAY send the same response generated when the request was first handled. KDCs MUST obey this replay behavior even if the actual transport in use is reliable.

Section 3.1.3

The authentication server looks up the client and server principals named in the KRB_AS_REQ in its database, extracting their respective keys. If the requested client principal named in the request is unknown because it doesn't exist in the KDC's principal database, then an error message with a KDC_ERR_C_PRINCIPAL_UNKNOWN is returned.

2. 客户端在 KRB_AP_REQ 消息中包含一个 Authenticator, 其中包含时间戳、序列号等信息。服务器在回复 KRB_AP_REP 消息时也需要生成一个 Authenticator, 其中包含时间戳、序列号等信息, 并使用相同的会话密钥进行加密。这种机制用于验证客户端的身份, 并防止重放攻击。

相关内容如下:

Section 3.2.1

The KRB_AP_REQ contains authentication information that SHOULD be part of the first message in an authenticated transaction. It contains a ticket, an authenticator, and some additional bookkeeping information (see Section 5.5.1 for the exact format). The ticket by itself is insufficient to authenticate a client, since tickets are passed across the network in cleartext (tickets contain both an encrypted and unencrypted portion, so cleartext here refers to the entire unit, which can be copied from one message and replayed in another without any cryptographic skill). The authenticator is used to prevent invalid replay of tickets by proving to the server that the client knows the session key of the ticket and thus is entitled to use the ticket. The KRB_AP_REQ message is referred to elsewhere as the 'authentication header'.

Section 3.2.2

When a client wishes to initiate authentication to a server, it obtains (either through a credentials cache, the AS exchange, or the TGS exchange) a ticket and session key for the desired service. The

Section 3.2.3

The algorithm for verifying authentication information is as follows. If the message type is not KRB_AP_REQ, the server returns the KRB_AP_ERR_MSG_TYPE error. If the key version indicated by the Ticket in the KRB_AP_REQ is not one the server can use (e.g., it indicates an old key, and the server no longer possesses a copy of the old key), the KRB_AP_ERR_BADKEYVER error is returned. If the USE-SESSION-KEY flag is set in the ap-options field, it indicates to the server that user-to-user authentication is in use, and that the ticket is encrypted in the session key from the server's TGT rather than in the server's secret key. See Section 3.7 for a more complete description of the effect of user-to-user authentication on all messages in the Kerberos protocol.

3. KRB_SAFE 消息包含用户数据和一个基于会话密钥的碰撞证明校验和。这种机制用于确保消息的完整性和真实性, 类似于挑战-响应中的“响应”。

相关内容如下:

Section 3.4.1

When an application wishes to send a KRB_SAFE message, it collects its data and the appropriate control information and computes a checksum over them. The checksum algorithm should be the keyed checksum mandated to be implemented along with the crypto system used for the sub-session or session key. The checksum is generated using the sub-session key, if present, or the session key. Some implementations use a different checksum algorithm for the KRB_SAFE messages, but doing so in an interoperable manner is not always possible.

Section 3.4.2

When an application receives a KRB_SAFE message, it verifies it as follows. If any error occurs, an error code is reported for use by the application.

4. KRB_PRIV 消息包含用户数据, 并使用会话密钥进行加密。这种机制用于确保消息的机密性, 类似于挑战-响应中的“响应”。

相关内容如下:

Section 3.5.1

When an application wishes to send a KRB_PRIV message, it collects its data and the appropriate control information (specified in Section 5.7.1) and encrypts them under an encryption key (usually the last key negotiated via subkeys, or the session key if no negotiation has occurred). As part of the control information, the client MUST

Section 3.5.2

When an application receives a KRB_PRIV message, it verifies it as follows. If any error occurs, an error code is reported for use by the application.

5. KRB_CRED 消息包含多个票据和相关信息，并使用会话密钥进行加密。这种机制用于安全地转发凭证，类似于挑战-响应中的“响应”。

相关内容如下：

Section 3.6.1

When an application wishes to send a KRB_CRED message, it first (using the KRB_TGS exchange) obtains credentials to be sent to the remote host. It then constructs a KRB_CRED message using the ticket or tickets so obtained, placing the session key needed to use each

ticket in the key field of the corresponding KrbCredInfo sequence of the encrypted part of the KRB_CRED message.

Section 3.6.2

When an application receives a KRB_CRED message, it verifies it. If any error occurs, an error code is reported for use by the application. The message is verified by checking that the protocol